UNITÀ 1 · LEZIONE 2 · LA CYBERSECURITY IN AZIENDA

Consulente per un giorno

Una piccola azienda ti chiede: "da dove cominciamo con la sicurezza, e quanto ci costa?". Rispondi come farebbe un consulente vero, con un registro dei rischi motivato.

Cosa consegni: un file **consulente-cognome.ods** con tre fogli (Asset, Rischi, Piano) su Novaula, nella scheda Compiti. **Scadenza:** quella indicata su Novaula.

Che cosa devi fare

1. Scegli un'azienda **inventata ma realistica** tra: agenzia di viaggi con 6 dipendenti, palestra con app per le prenotazioni, laboratorio di analisi mediche con 40 dipendenti. Descrivila in 3 righe in cima al foglio **Asset**.
2. Nel foglio **Asset** elenca almeno **8 asset** (informazioni, sistemi, persone e fornitori) con proprietario e importanza per riservatezza, integrità e disponibilità (bassa, media, alta).
3. Nel foglio **Rischi** compila almeno **10 righe**: asset, minaccia, vulnerabilità, P, I, R = P × I, livello con la funzione `SE`, trattamento (mitigare, trasferire, evitare, accettare), contromisura.
4. Ordina per rischio decrescente. Per i 3 rischi più alti scrivi il rischio residuo atteso dopo la contromisura.
5. Nel foglio **Piano**: RTO e RPO del processo più importante, le contromisure divise per funzione NIST CSF 2.0 (Govern, Identify, Protect, Detect, Respond, Recover) e un paragrafo: la tua azienda rientra nella NIS2? Motiva con settore e dimensione.

Esempio di riga del foglio Rischi

Asset	Minaccia	Vulnerabilità	P	I	R	Livello	Trattamento	Contromisura
Agenda prenotazioni in cloud	Furto credenziali	Solo password, condivisa	4	4	16	Alto	Mitigare	Account personali con MFA

> *"La sicurezza è un processo, non un prodotto."* · **Bruce Schneier**, *Secrets and Lies, 2000 (traduzione nostra). Il tuo registro non è finito: indica anche ogni quanto andrebbe rivisto.*

Come viene valutato

Criterio	Punti
Inventario degli asset completo, con proprietario e valori CIA	2
Registro dei rischi: 10 righe coerenti, formule corrette, ordinamento	3
Trattamenti e contromisure adatti, rischio residuo dei primi 3	2
Piano: RTO/RPO, funzioni CSF, valutazione NIS2 motivata	2
Cura del file e motivazione dei numeri	1

L'azienda deve essere inventata: non usare nomi, dati o configurazioni reali di aziende che conosci. Per la NIS2 puoi consultare il sito dell'ACN (acn.gov.it).